

腾讯云蜜罐开发实战

方锦旭 · JINXU

2021首届-西部云安全峰会
Western China Cloud Security Summit 2021



WHO IS JINXU:

- 腾讯安全 · 安全研究员
- 自动化安全研究：腾讯云漏扫
- Internet安全研究：网络空间测绘 / 云蜜罐
- A&D Team 核心成员

WHO IS A&D TEAM:

腾讯安全产品部门的攻防团队，关注云上租户的安全。

研究方向:

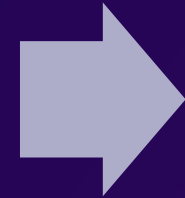
漏洞挖掘 / 红蓝对抗 / 容器安全 ...

Pwn20wn: 首届破解大师、2017年总冠军

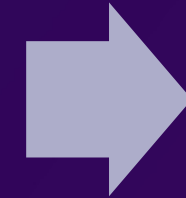
GeekPwn 破解海尔智能套装、1秒 攻破Surface Pro4

CSS、BlackHat Europe 等国际会议演讲

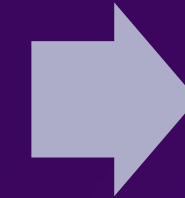
背景介绍



技术架构



数据洞察



案例介绍

真实的Internet现状：攻击行为无处不在

```
64.32.255.120 - - [20/Aug/2021:01:14:45 +0800] "GET / HTTP/1.1" 200 555 "-" "-"
183.50.133.230 - - [20/Aug/2021:01:15:06 +0800] "\x05\x01\x00" 400 166 "-" "-"
42.192.78.15 - - [20/Aug/2021:01:15:25 +0800] "\x05\x01\x00" 400 166 "-" "-"
42.192.78.15 - - [20/Aug/2021:01:15:31 +0800] "\x05\x01\x00" 400 166 "-" "-"
183.50.133.230 - - [20/Aug/2021:01:16:40 +0800] "\x05\x01\x00" 400 166 "-" "-"
117.35.44.110 - - [20/Aug/2021:01:18:54 +0800] "\x05\x01\x00" 400 166 "-" "-"
VM-16-4-ubuntu# zcat access.log.12.gz|grep -v Ping |tail -n 10
203.105.117.230 - - [20/Aug/2021:20:40:49 +0800] "POST /boaform/admin/formLogin HTTP/1.1" 404 143 "http://124.156.148.70:80/admin/login.asp" "Mozilla/5.0 (X
1; Linux; Ubuntu; Linux x86_64; rv:71.0) Gecko/20100101 Firefox/71.0"
203.105.117.230 - - [20/Aug/2021:20:40:50 +0800] "" 400 0 "-" "-"
167.348.115.39 - - [20/Aug/2021:22:15:01 +0800] "GET / HTTP/1.1" 200 555 "-" "-"
167.348.115.39 - - [20/Aug/2021:22:15:02 +0800] "GET / HTTP/1.1" 200 360 "-" "Mozilla/5.0 (compatible; CensysInspect/1.1; +https://about.censys.io/)"
42.192.78.15 - - [20/Aug/2021:22:19:28 +0800] "GET /phpmyadmin4.8.5/index.php HTTP/1.1" 404 200 "-" "Mozilla/5.0 (Linux; Android 10; LIO-AN00 Build/HUAWEIL
0-7.100; AppleWebKit/537.36 (KHTML, like Gecko) Version/4.0 Chrome/78.0.3904.62 XWEB/2692 MMWBS SDK/200901 Mobile Safari/537.36"
194.45.33.145 - - [20/Aug/2021:22:53:04 +0800] "GET /config/getuser?index=0 HTTP/1.1" 404 143 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:76.0) Gecko/2
100.2.110.135 - - [20/Aug/2021:23:14:07 +0800] "POST /boaform/admin/formLogin HTTP/1.1" 404 143 "http://124.156.148.70:80/admin/login.asp" "Mozilla/5.0 (X
1; Linux; Ubuntu; Linux x86_64; rv:71.0) Gecko/20100101 Firefox/71.0"
203.105.117.235 - - [20/Aug/2021:23:14:08 +0800] "" 400 0 "-" "-"
77.79.1.101 - - [20/Aug/2021:23:20:56 +0800] "GET / HTTP/1.1" 400 166 "-" "-"
92.119.244.133 - - [20/Aug/2021:23:39:22 +0800] "GET / HTTP/1.0" 200 543 "-" "NetSystemsResearch studies the availability of various services across the inte
net. Our website is netsystemsresearch.com"
VM-16-4-ubuntu#
```

尝试解答：

- 1) 谁在做攻击？
- 2) 用的什么攻击手法？

采取如下行动：

1. 构建蜜罐集群，进行流量的自动收集
2. 分析攻击型流量，感知在野攻击行为

云蜜罐：到底要做什么？

背景介绍

技术架构

数据洞察

案例介绍

黑暗森林理论：“一旦某个宇宙文明被发现，就必然遭到其他宇宙文明的打击。”

对抗黑暗森林：“制作一个虚假的宇宙文明，引诱其他宇宙文明的攻击，通过观察打击方式，以进行针对性防御。”

1. 制作虚假的宇宙文明

2. 引诱其他宇宙文明的攻击

3. 观察打击方式，研究对策

背景介绍

技术架构

数据洞察

案例介绍

云蜜罐的系统架构：依托腾讯云原生组件构建

3. 数据存储挖掘 (观察打击方式)

消息队列 CKAFKA

云函数SCF

TDSQL-H 海量日志存储

数据分析挖掘

2. 搭建公网集群 (引诱其他文明攻击)

CODING 自动构建镜像

TCR 镜像托管

TKE 边缘集群

腾讯云CVM / 轻量云主机

1. 开发蜜罐探针 (虚假的宇宙文明)

协议自识别

高交互蜜罐集群

多应用伪装

全端口开放

在10台腾讯云主机上的结果：
1) 每日收到扫描数据：1000w+
2) 每日去重的攻击IP数：1w+

1) 蜜罐探针思考：如何吸引更多攻击火力？

最理想的情况：在Internet的每一台机器上安装探针，上报收到的攻击行为。

但是：资源是有限的，公网IPv4地址十分宝贵，只能部署有限的蜜罐节点。

所以：需要最大化提高单节点的攻击捕获能力。



1. 全端口监听

收集针对全端口攻击



2. 多应用伪装

收集针对应用的攻击



什么？又被搞了？
SSH弱口令进去的？

3. 协议识别分流

收集非HTTP攻击

创建文明 – 使用透明代理监听全端口流量

原因：攻击者的行为是不可预知的，可能对任一端口发起攻击。蜜罐需要具备对全端口的流量感知能力。
实现方式：使用Linux内核提供的透明代理技术实现本机 60000+的端口流量监听。

问题：传统的SOCKET编程不支持全端口绑定

1. SOCKET 编程：只支持绑定单个端口。

```
s = socket(AF_INET, SOCK_STREAM)
s.bind(('127.0.0.1', 1234))
s.listen(32)
```

2. 若绑定全端口(1-65535) 将占用大量系统资源。且影响机器的TCP出站流量，不可取。

```
s = socket(AF_INET, SOCK_STREAM)
s.setsockopt(IPPROTO_IP, IP_TRANSPARENT, 1)
for i in range(1,65535):
    s.bind(('127.0.0.1', i))
s.listen(32)
```

❌不可取

透明代理（TPROXY）：Linux内核提供的透明代理机制，可在不更改数据数文的情况下将数据报文转发到本地的socket。

1. 修改SOCKET的描述符：设置IP_TRANSPARENT属性

```
s = socket(AF_INET, SOCK_STREAM)
s.setsockopt(IPPROTO_IP, IP_TRANSPARENT, 1)
s.bind(('127.0.0.1', 1234))
s.listen(32)
```

2. 配置iptables，对入站流量进行转发

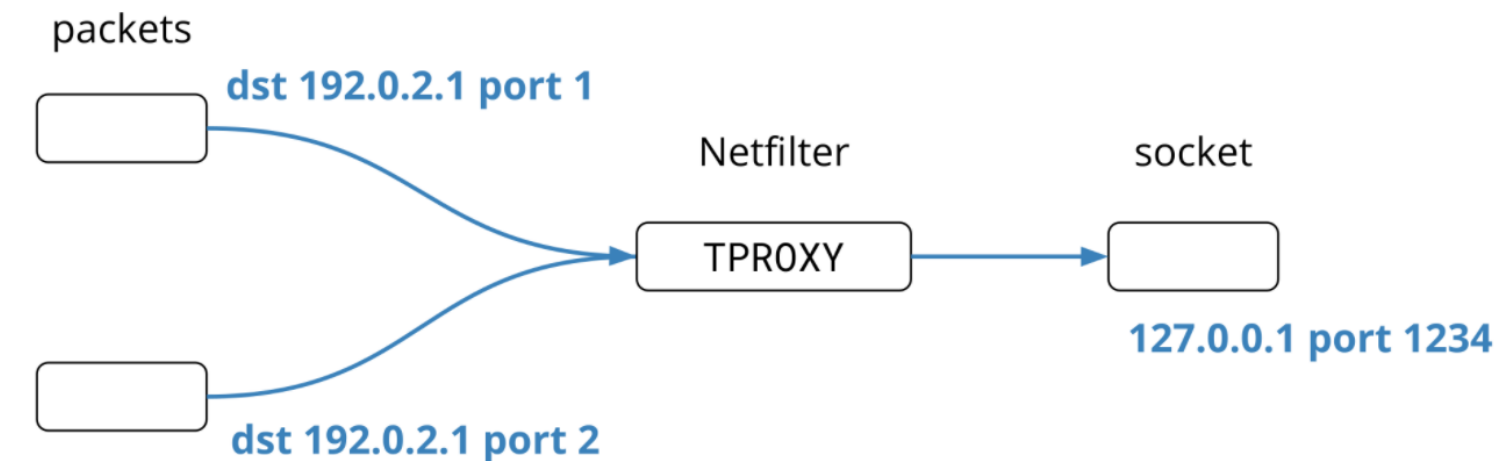
```
sudo iptables -t mangle -A PREROUTING -p tcp -j TPROXY
--tproxy-mark 0x1/0x1 --on-port 1234 --on-ip 127.0.0.1
```

全端口监听

多应用伪装

协议自识别

实现效果：单机可捕获针对 6w+端口的攻击



M:1 mapping

（图片来自网络）

精准应答 1 - 多应用伪装，伪装常见组件特征

精准应答：吸引攻击

不要回答
不要回答
不要回答

回答 = 被攻击

精准应答

增大被攻击概率

多应用伪装：在网页中放置大量的常用组件的特征，吸引攻击。

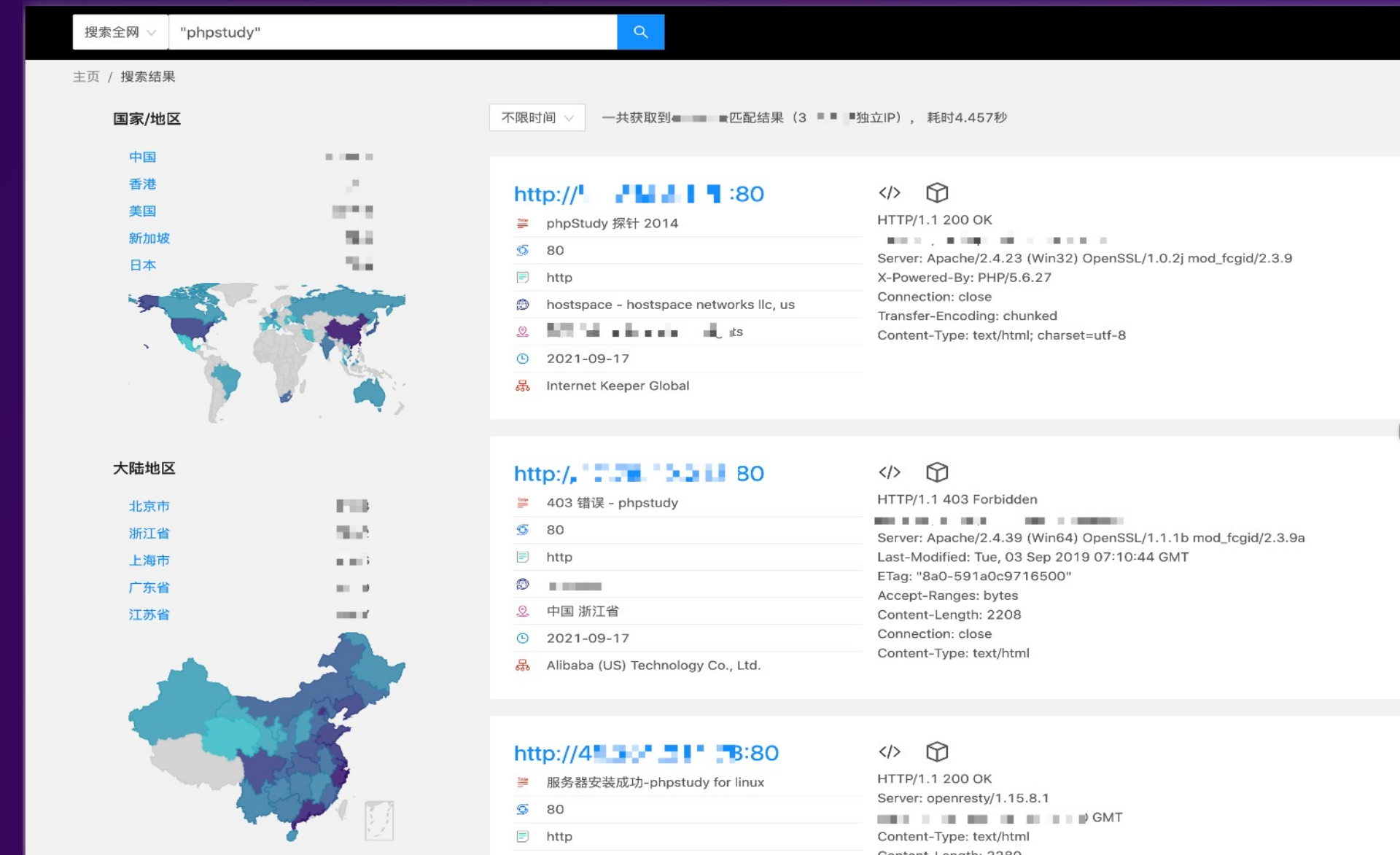
```
<html>
  <title>Welcome to PHPStudy</title>
  <title>client</title>
  <title>DVR Components Download</title>
  <title>FatPipe MPVPN Remote Configuration</title>
  <title>Apache HTTP Server Test Page powered by CentOS</title>
  <title>Apache Tomcat/5.0.28 - Error report</title>
  <title>GlassFish Server Open Source Edition 4.1.1 - Error report</title>
  <title>BLS</title>
  <title>Apache2 Debian Default Page: It works</title>
  <title>IIS Windows Server</title>
  <title>hd client</title>
  <title>GPON Home Gateway</title>
  <title>Home</title>
  <title>Cross Error</title>
  <title>AppServ Open Project 8.6.0</title>
  <title>Dashboard [Jenkins]</title>
  <title>LANMP一键安装包</title>
  <title>IIS7</title>
  <title>HTML Online Editor Sample</title>
  <title>City Track 3.0</title>
  <title>Coremail邮件系统</title>
  <title>Apache2 Ubuntu Default Page: It works</title>
  .....
</html>
```

全端口监听

多应用伪装

协议自识别

原因：黑客常用的Google Hack的方式寻找攻击目标，即通过搜索引擎，通过攻击偏好进行检索，获取攻击目标。



精准应答 2 – 协议自动识别，单端口支持多协议

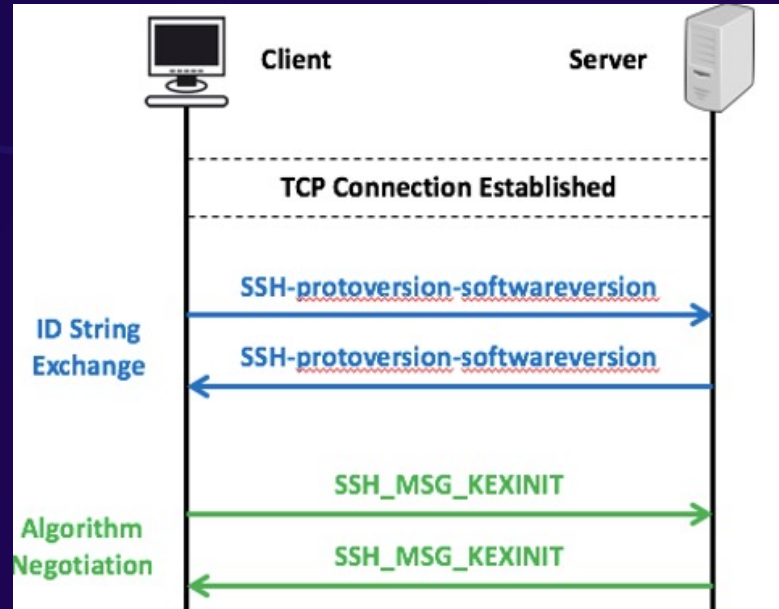
实现方式：通过识别首包特征实现端口复用、在单端口处理多协议。

全端口监听

多应用伪装

协议自识别

SSH协议：首包特征 SSH-\d



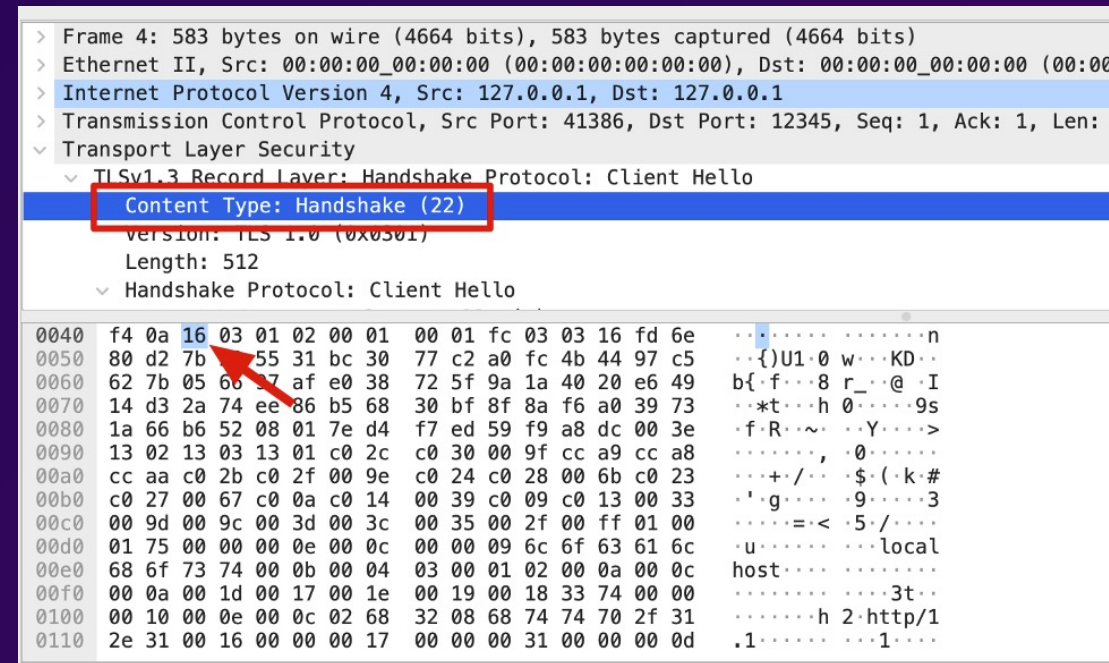
SSH服务的握手流程

```
> ssh localhost -p 2222
```

```
sudo nc -l 2222  
SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.2
```

使用nc模拟服务器查看首包特征

TLS首包特征：\x16



实现：单端口同时接收三种协议的攻击

```
~ curl -I :80  
HTTP/1.1 200 OK  
Content-Type: application/json  
Server: BigIP Docker/1.13.1 (linux),docker 1.20,Jboss,Apache-Coyote/1.1,WildFly/10  
ess N ADSL2+ Modem Router TD-W8960N,::: Login :::,ADSL2 PLUS,AGS GmbH Webserver Se  
ers Guild | IATSE local 892,D-LINK SYSTEMS, INC. | WIRELESS ROUTER | HOME,DIR600  
e: RP2520,FiberLink101,GOTHAN,GPON Home Gateway,GREATEK,GWR-120,Game of Life,Gial  
  
~ ssh -p 80  
The authenticity of host '[REDACTED]:80 ([REDACTED]:80)' can't be established.  
RSA key fingerprint is SHA256:[REDACTED].  
Are you sure you want to continue connecting (yes/no/[fingerprint])? ^C  
  
~ openssl s_client -showcerts :80  
  
CONNECTED(00000003)  
Can't use SSL_get_servername  
depth=0 CN = example.com  
verify error:num=18:self signed certificate  
verify return:1  
depth=0 CN = example.com  
verify return:1  
---  
Certificate chain  
0 s:CN = example.com  
i:CN = example.com  
-----BEGIN CERTIFICATE-----
```


小结：通过三种方式，提升蜜罐的单节点攻击捕获能力

全端口监听

多应用伪装

协议自识别

65535个端口 x 3种协议(TLS/SSH/HTTP)

HTTP协议 -> 100+种应用

优化成果：使用全端口开放技术和多应用伪装技术后，在10个蜜罐节点单接收到流量
1000w+

2) 蜜罐集群思考：如何实现蜜罐节点的管理和代码上线？

背景介绍

技术架构

数据洞察

案例介绍

蜜罐感知的范围：全球的、跨地域的。

节点的维护方式：自动化的。

代码发布：自动化的、可回滚的。

复杂问题简单化：通过复用腾讯云的基础组件实现全球蜜罐节点管理

背景介绍

技术架构

数据洞察

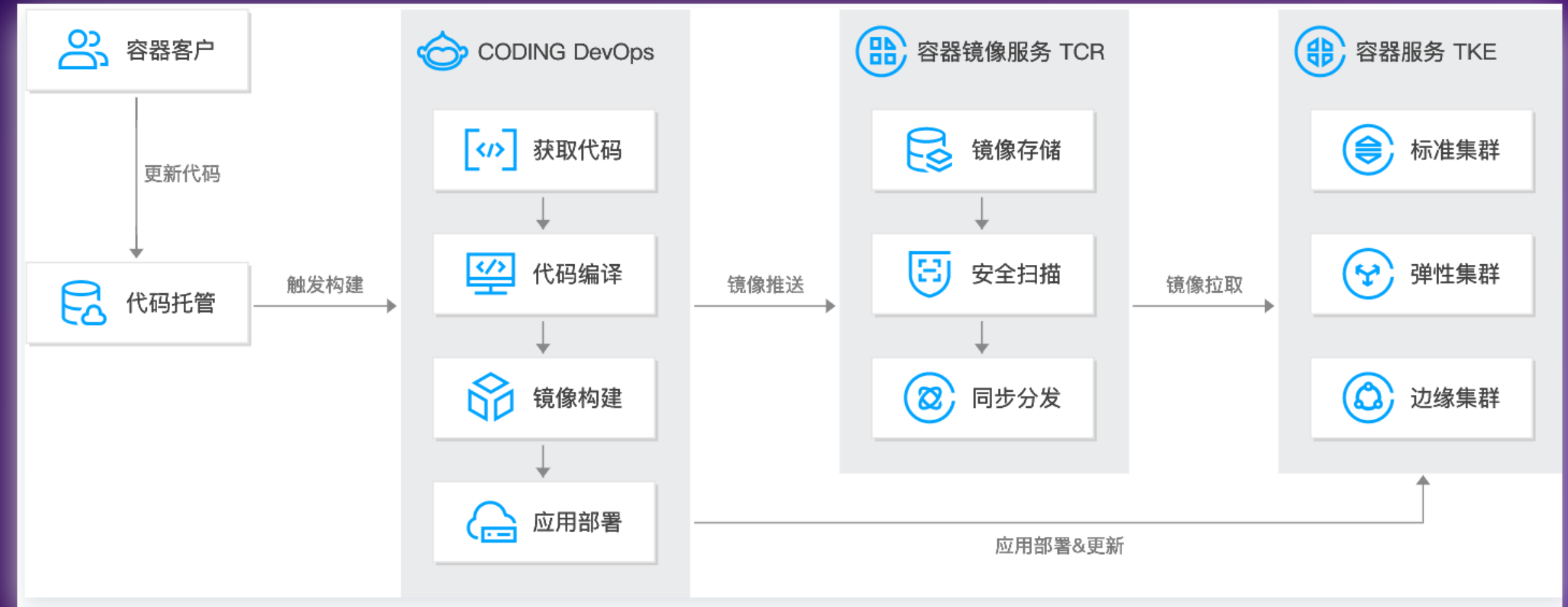
案例介绍

1. Coding 代码平台实现安全扫描和镜像的构建

2. 容器技术实现运行时环境的一致

3. TCR 容器镜像服务进行代码的分发

4. TKE 实现对蜜罐节点的健康监测和探针容器管理

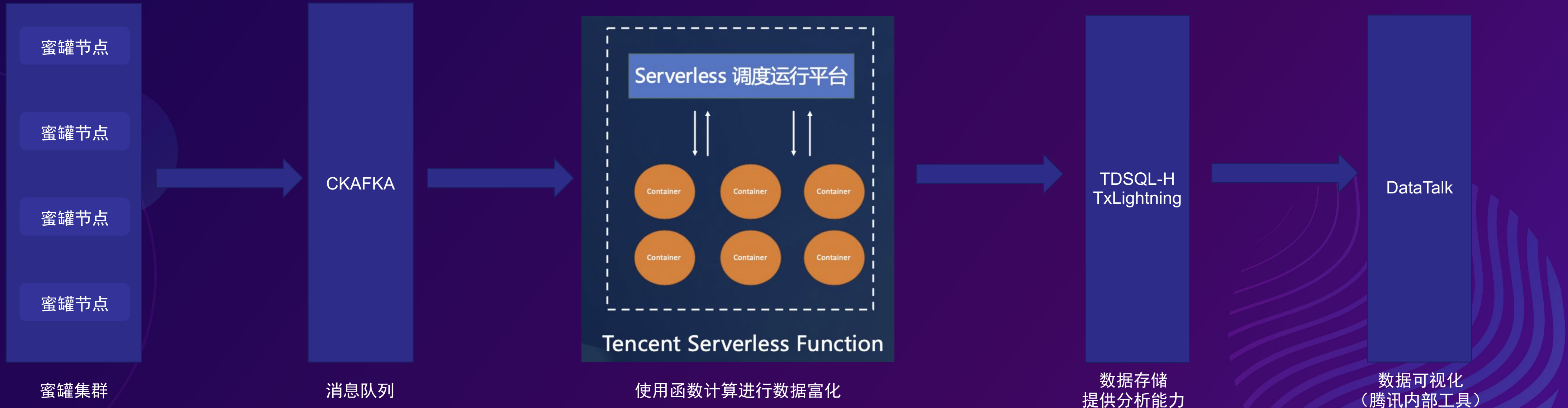


3) 数据存储和分析：蜜罐数据的存储与可视化分析

数据量大：每日超过一千万条

加工工序多：IP地理位置、IP归属信息、RDNS信息、测绘信息...

分析维度多：IP维度、端口维度、URL维度、URL参数维度、URL路径维度、时间维度...



云蜜罐数据8月运营数据：日均 1千万流量，收集恶意IP数 17.8万个

背景介绍

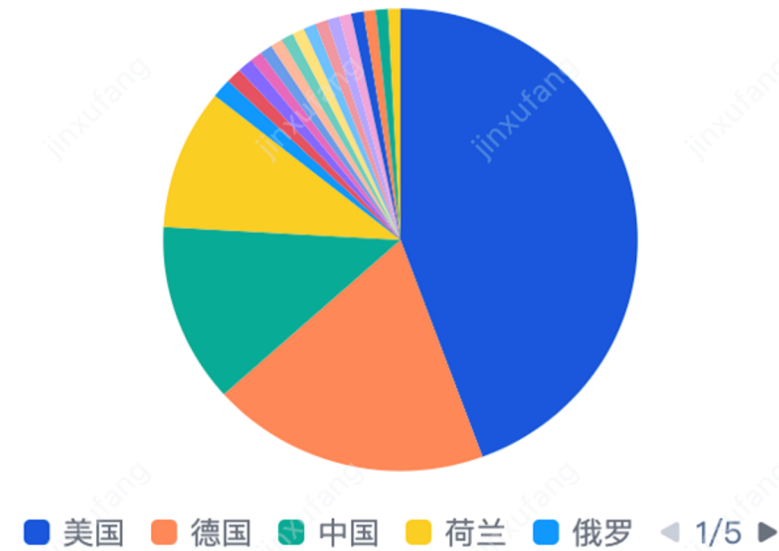
技术架构

数据洞察

案例介绍

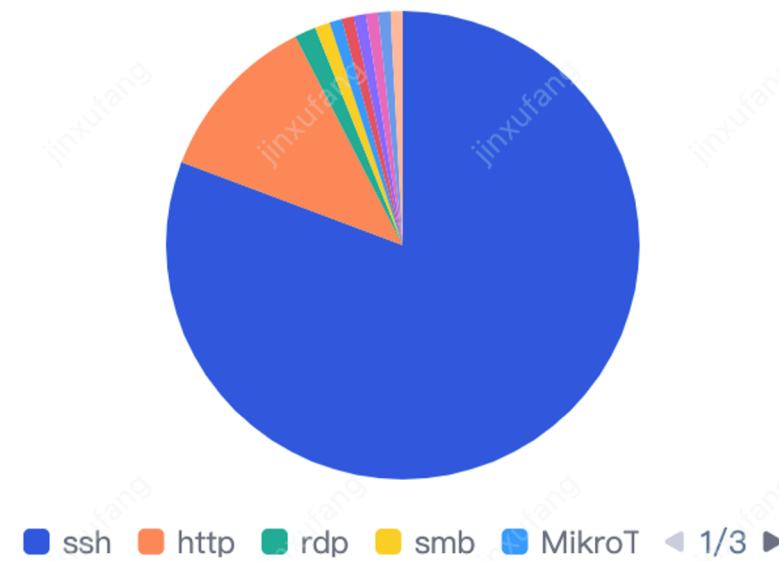
8月累积收到3亿+条扫描流量，以境外IP和SSH爆破流量居多

流量分布情况
国外IP贡献流量居多



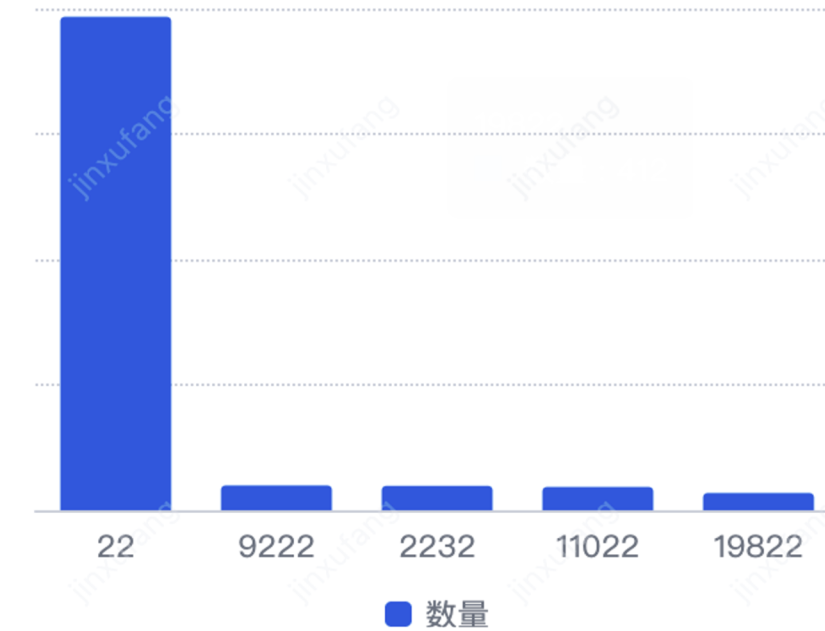
流量来源情况：境外IP贡献占比超过 80%。

协议分布
SSH 爆破流量占比超过80%



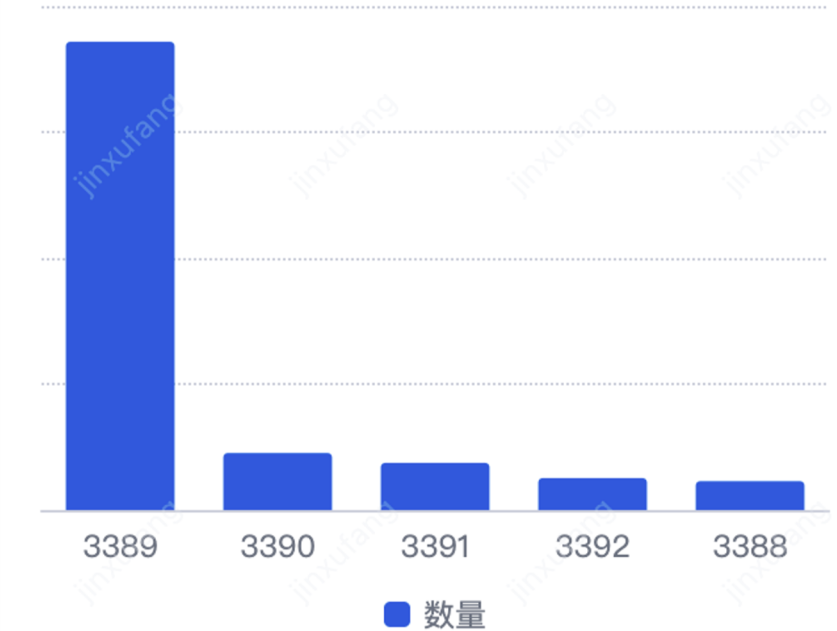
组成成分：SSH扫描流量占比超 80%

SSH 协议目的端口 Top5



SSH扫描：偏爱带22的端口

RDP 协议目的端口Top5



RDP扫描：从3389端口号递增

HTTP(S) 流量分析：以命令执行类漏洞和扫描器流量为主

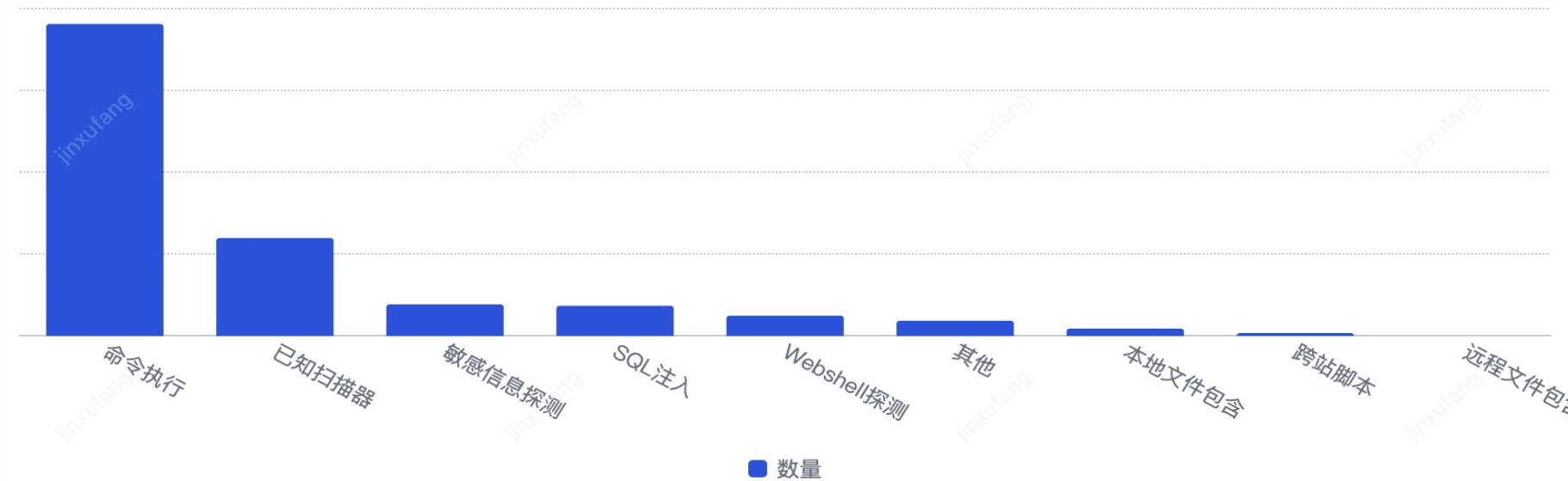
背景介绍

技术架构

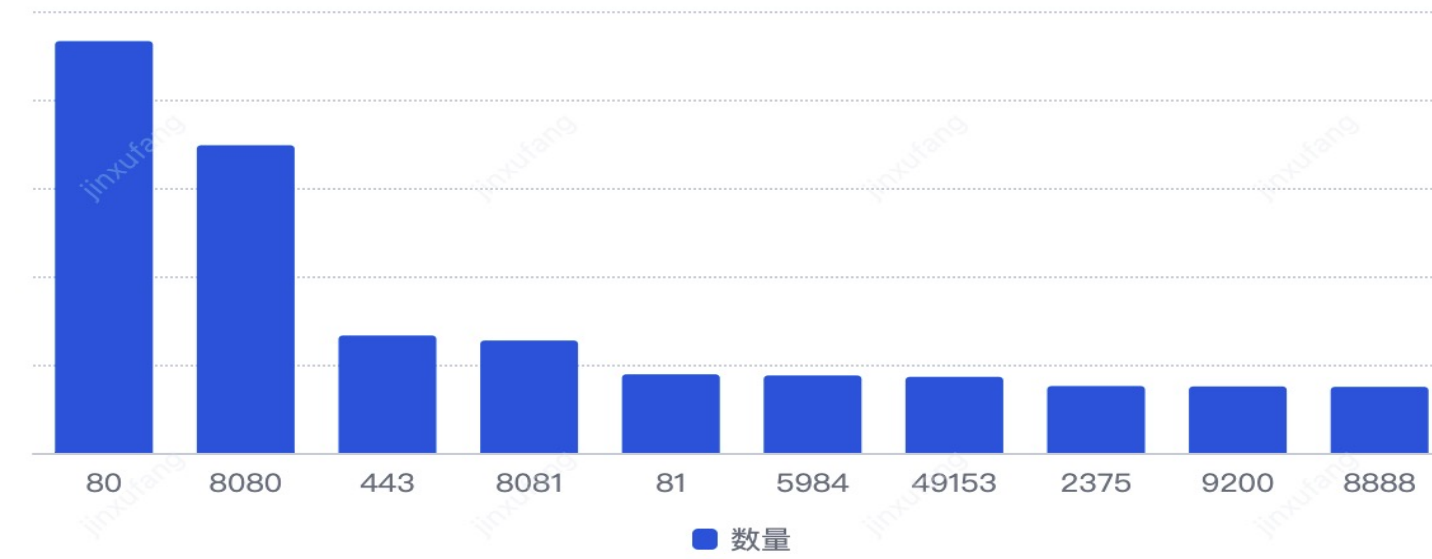
数据洞察

案例介绍

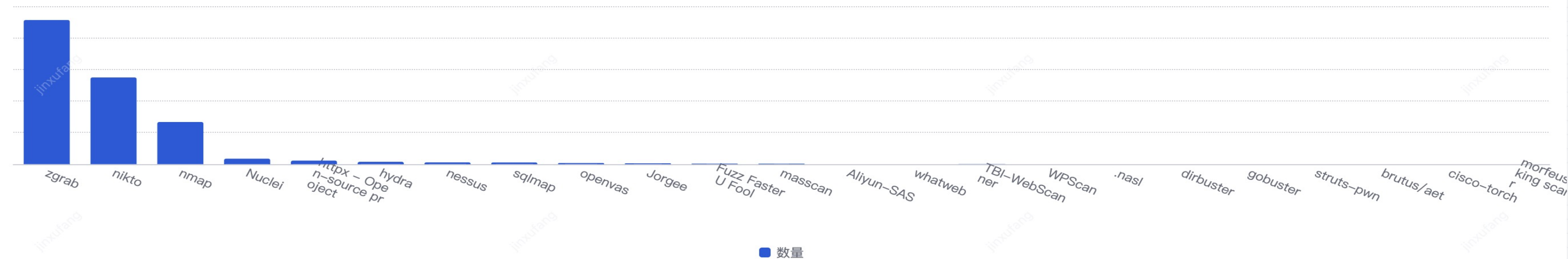
HTTP 流量攻击类型分布



HTTP 流量Top10端口



已知扫描器排行



案例：Confluence远程命令执行（CVE-2021-26084）

背景介绍

技术架构

数据洞察

案例介绍

2021年8月25日

Atlassian官方发布安全通告，披露了一个Atlassian Confluence远程代码执行漏洞（CVE-2021-26084），攻击者利用漏洞可以完全控制服务器

2021年8月26日

腾讯安全发布风险通告

8月25日：官方发布安全通告，存在安全漏洞

8月26日：腾讯安全工程师分析：危害极大，发布安全通告，提醒客户升级。

2021年8月31日

腾讯安全捕获Confluence远程代码执行漏洞

2021年9月1日

漏洞poc公开在Github

8月31日晚：云蜜罐捕捉到在野利用，再次发布安全通告。

首个攻击IP：185.56.80.xx，为TOR 洋葱网络出口节点。

2021年9月1日晚

腾讯安全检测到多个不同挖矿木马、僵尸网络团伙利用Confluence远程代码执行漏洞攻击云主机

9月1日晚：漏洞开始被挖矿木马和僵尸网络集成。

截止 9-17：共捕获到 8个黑产团伙（6个挖矿家族、2个僵尸网络家族）使用此漏洞进行攻击

蜜罐视角看到的Confluence RCE 漏洞

背景介绍

技术架构

数据洞察

案例介绍

1. 累计接收到 13w+的攻击，攻击源仍以境外IP为主。
2. 捕获IP数 244，其中185.56.80.xx 为首次攻击IP。
3. POC公布之后的第三天利用数达到高峰，十天后再次达到小高峰。

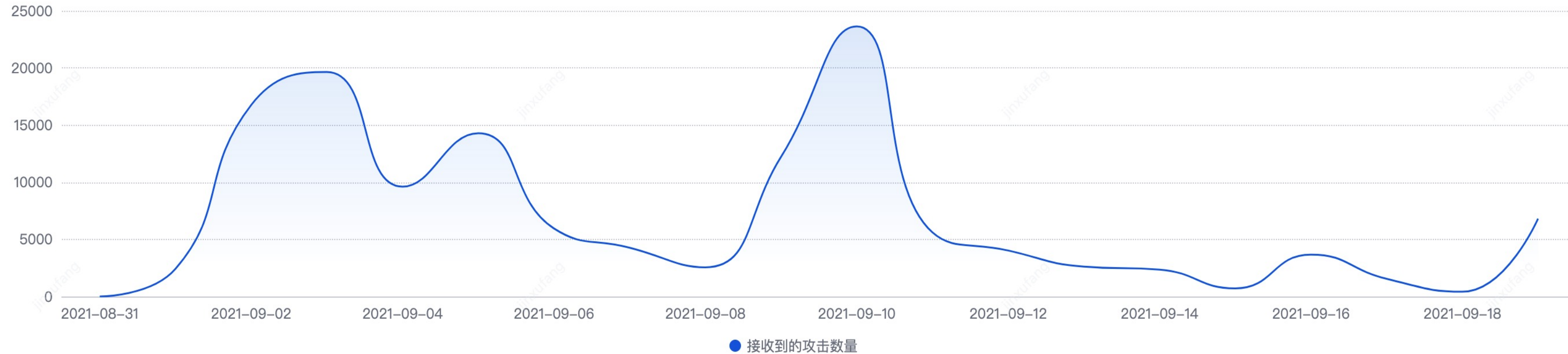
CVE-2021-26084 流量数

139,216

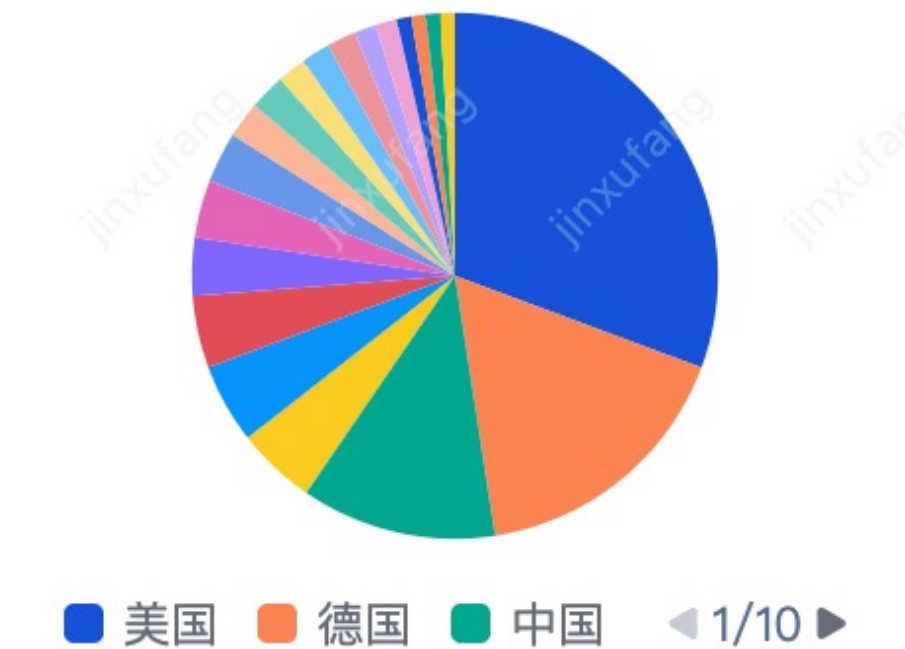
捕获到的攻击IP数

244

漏洞利用趋势



IP来源占比情况



总结

云蜜罐探针：
使用三种技术做优化

节点管理：
使用腾讯云
TKE和容器技术

数据分析：
使用TDSQL-H
数据库存储
和分析蜜罐
数据

最终效果：
日收集kw级
流量，并可
感知热点漏
洞的攻击行
为。

云上的安全充满机会和挑战，欢迎同学们加入



A&D-Team 公众号



个人微信号



感谢聆听
Thanks

● 2021首届-西部云安全峰会
Western China Cloud Security Summit 2021